

Атаки и защиты Linux-систем

Алина Кальсберг

Эксперт. Отдел анализа
киберугроз и форензики VK

Skillbox

образовательная платформа

Цели модуля

- 1 Узнать, каким атакам подвержены Linux-системы
- 2 Определить, где искать следы деятельности злоумышленников в Linux-системах
- 3 Разобраться, как провести Security Hardening и защитить систему от взлома

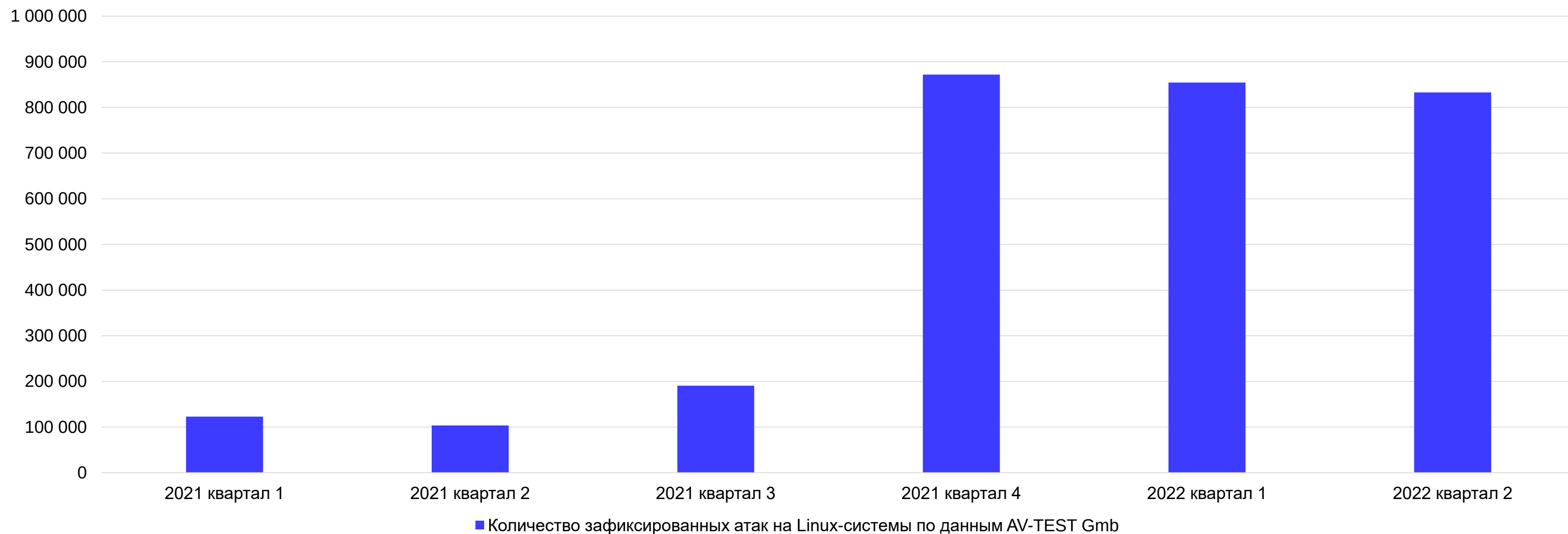
Атаки на Linux-системы

Цели

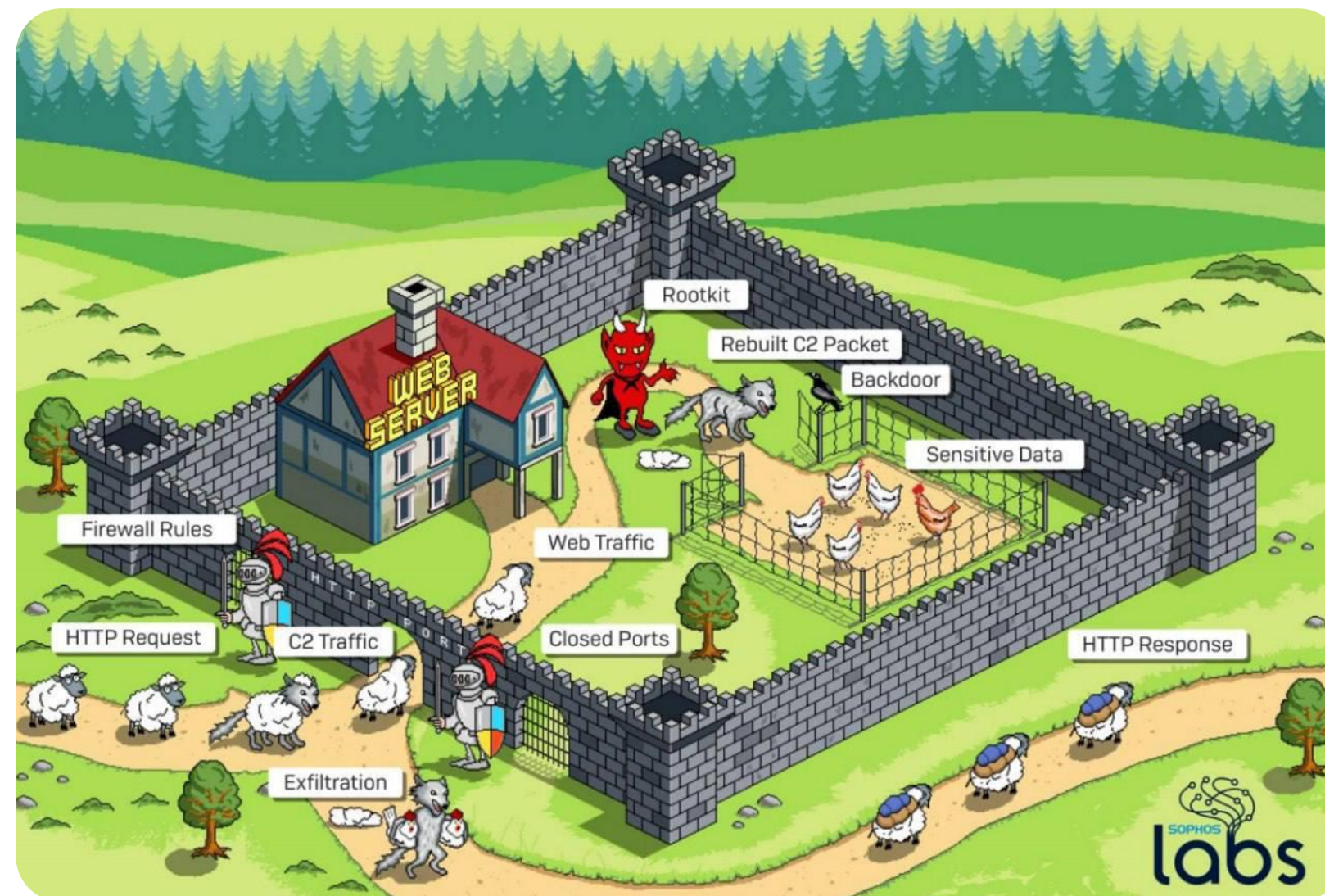
- 1 Узнать, какие типы атак бывают
- 2 Познакомиться с сетевыми атаками
- 3 Познакомиться с атаками на ОС Linux

Немного статистики

Количество зафиксированных атак на Linux-системы по данным AV-TEST Gmb



Из-за чего происходит взлом?



Изображение: [Cloud Snooper attack](#)

Из-за чего происходит взлом?

- Недостатки фильтрации трафика
- Уязвимости веб-приложений
- Использование небезопасных приложений и API
- Недостатки управления уязвимостями и обновлениями
- Плохое управление доступом
- Недостатки конфигураций
- Использование неутверждённых отделом безопасности инструментов
- Плохая осведомлённость пользователей в вопросах информационной безопасности

Сетевые атаки

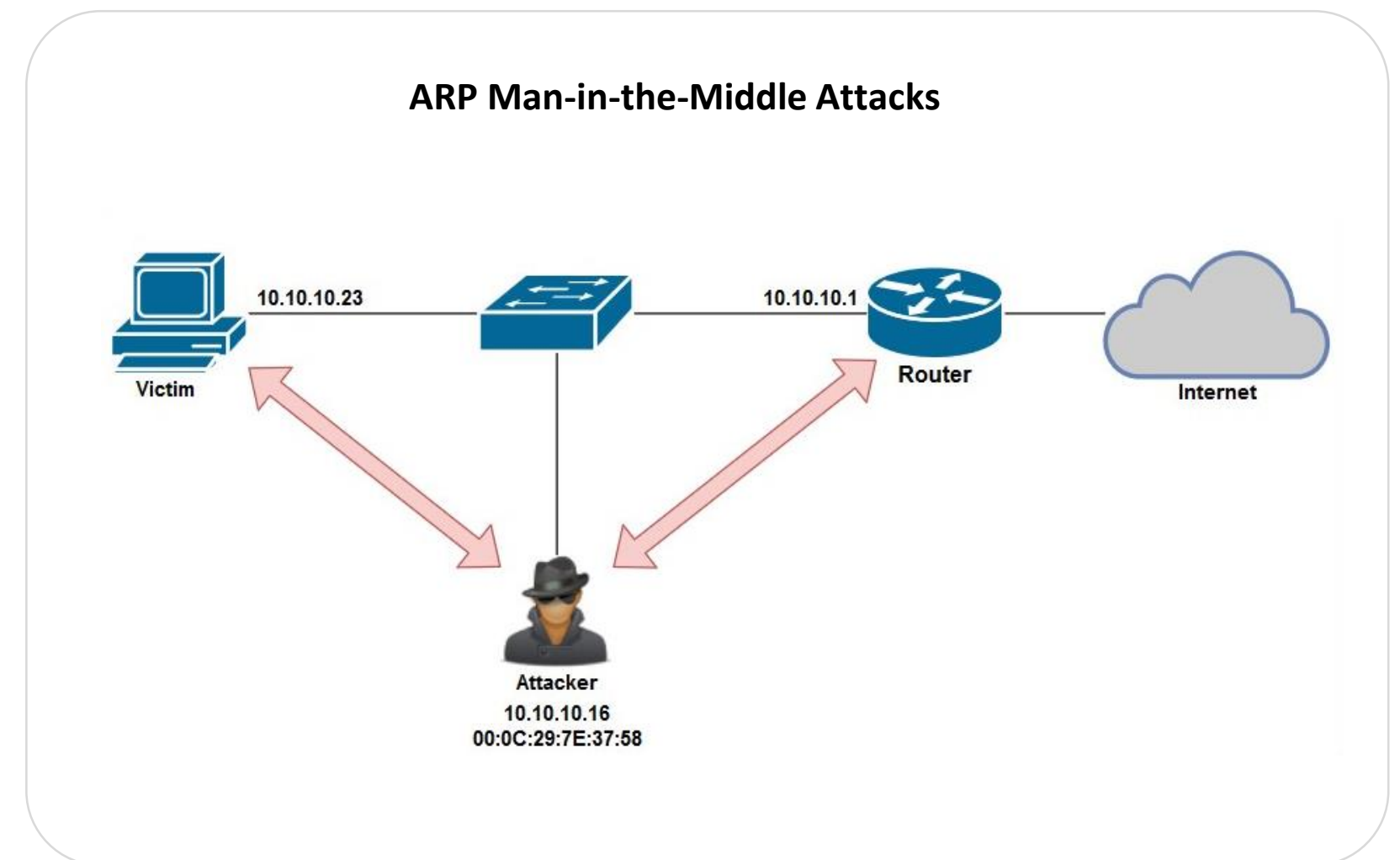
- Атаки на ARP
- Атаки на DNS
- Атаки типа Spoofing
- SYN Flood-атаки
- Dos/DDoS



Изображение: [DDoS-атака](#)

ARP-атаки, или отравление ARP

Недостаток ARP-протокола: не имеет защиты и верит любому ответному ARP-пакету. Злоумышленники могут создавать ответные ARP-пакеты с поддельными MAC-адресами, отравляя таблицу ARP.



Изображение: [Detecting ARP poisoning attacks](#)

Атаки на DNS

DNS poisoning attack

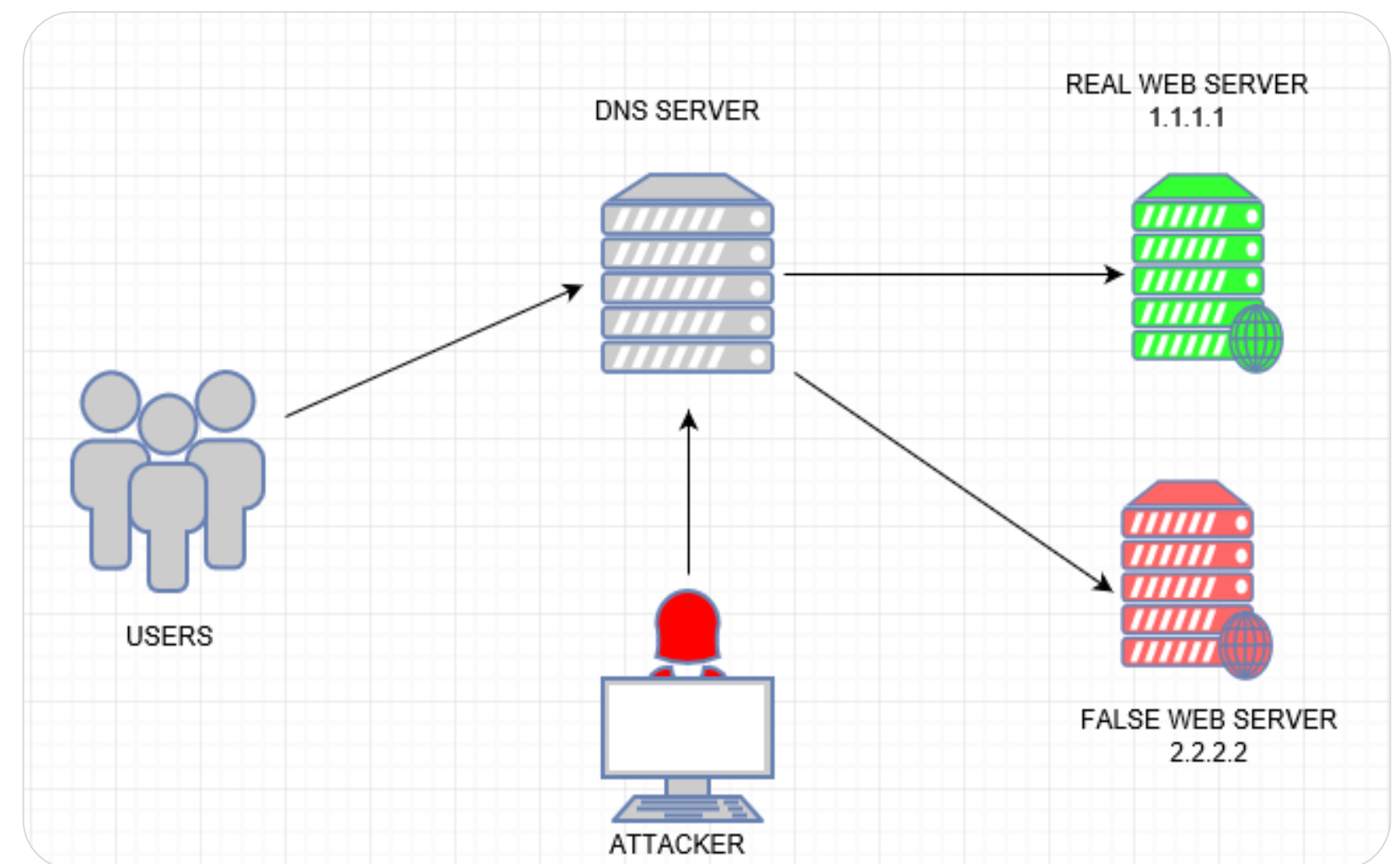
Модификация/повреждение DNS приводит к изменению законного IP-адреса, связанного с веб-сайтом, и замене его IP-адресом другого веб-сайта.

DNS pharming attack

Перенаправляет пользователя на другой веб-сайт путём изменения файла hosts, используемого для сопоставления IP-адресов с именами хостов.

Amplification DNS attacks

Увеличивают объём трафика, отправляемого или запрашиваемого у жертвы, и могут использоваться против самых разных систем, включая отдельные хосты, DNS-серверы и NTP-серверы.



Изображение: [DNS protocol attacks](#)

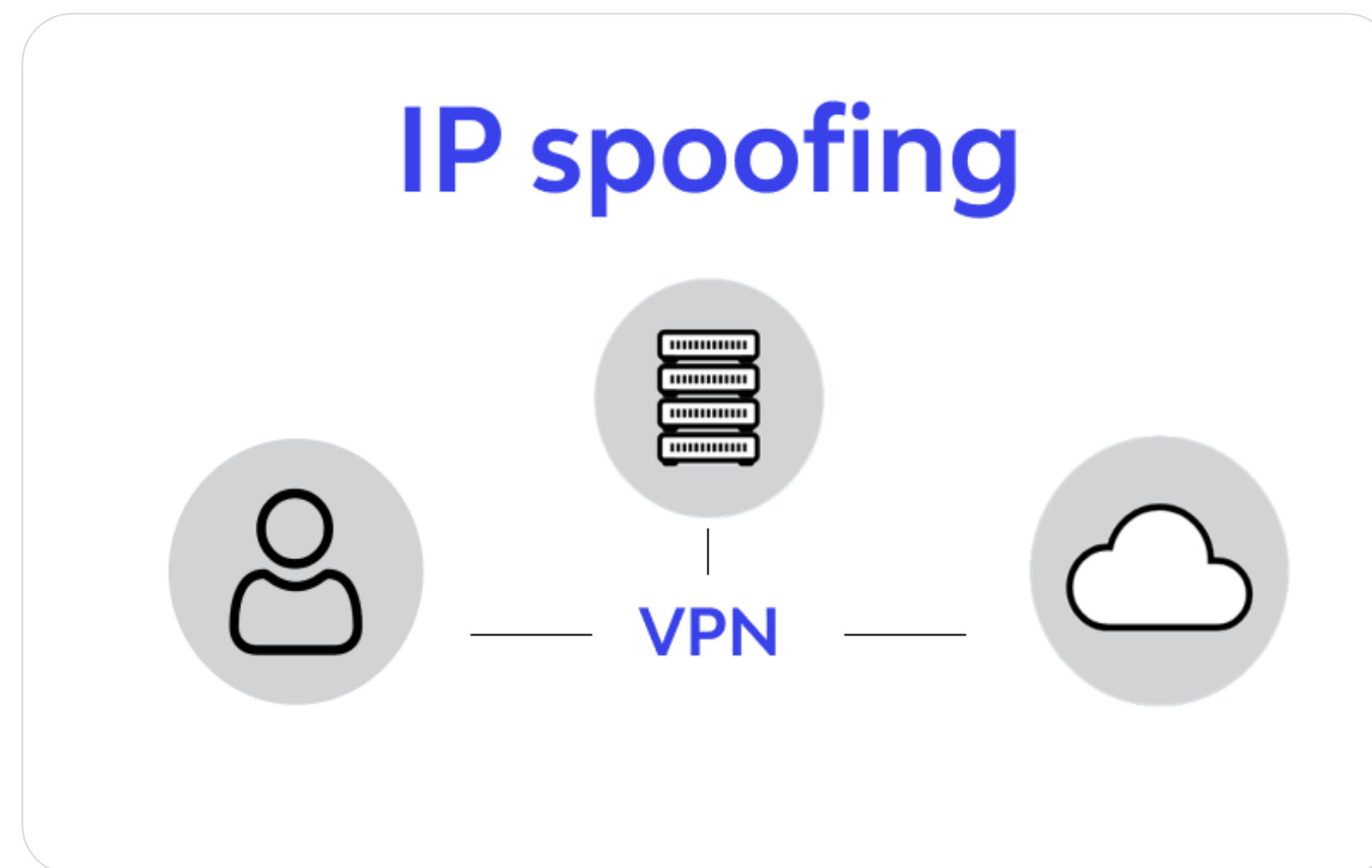
Атаки типа Spoofing

Атаки на MAC

Подмена MAC-адреса (MAC flood attacks). Обход фильтрации MAC-адресов (Circumventing MAC address filtering).

Атаки на IP

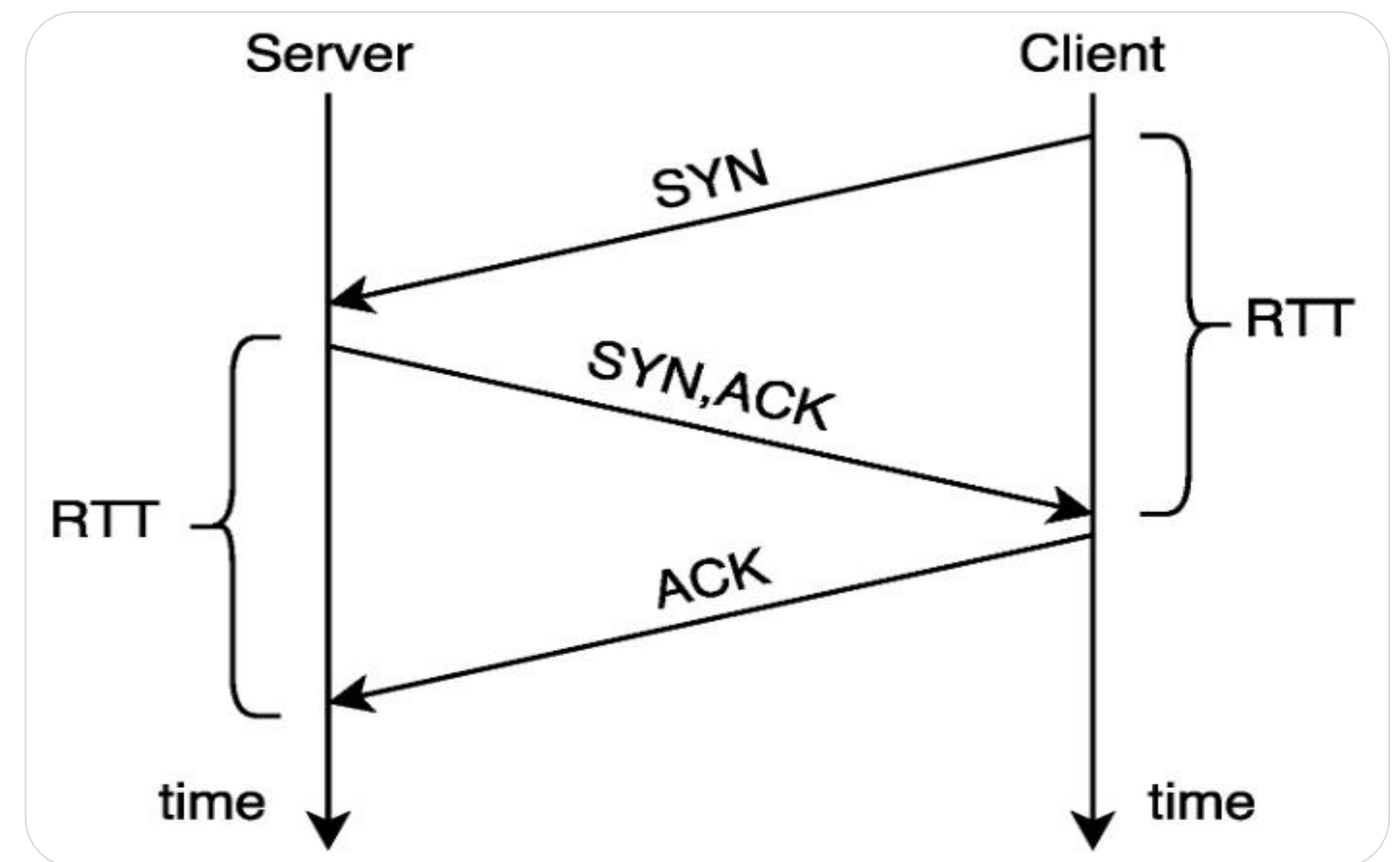
Подмена IP или IP address spoofing.



Изображение: [IP Spoofing. Definition, Types And Protection](#)

Атаки типа SYN Flood

- Злоумышленник никогда не завершает рукопожатие, а вместо этого отправляет шквал SYN-пакетов
- Полуоткрытые соединения потребляют ресурсы, пока ожидают завершающего пакета
- После достижения определённого количества сервер перестаёт принимать подключения

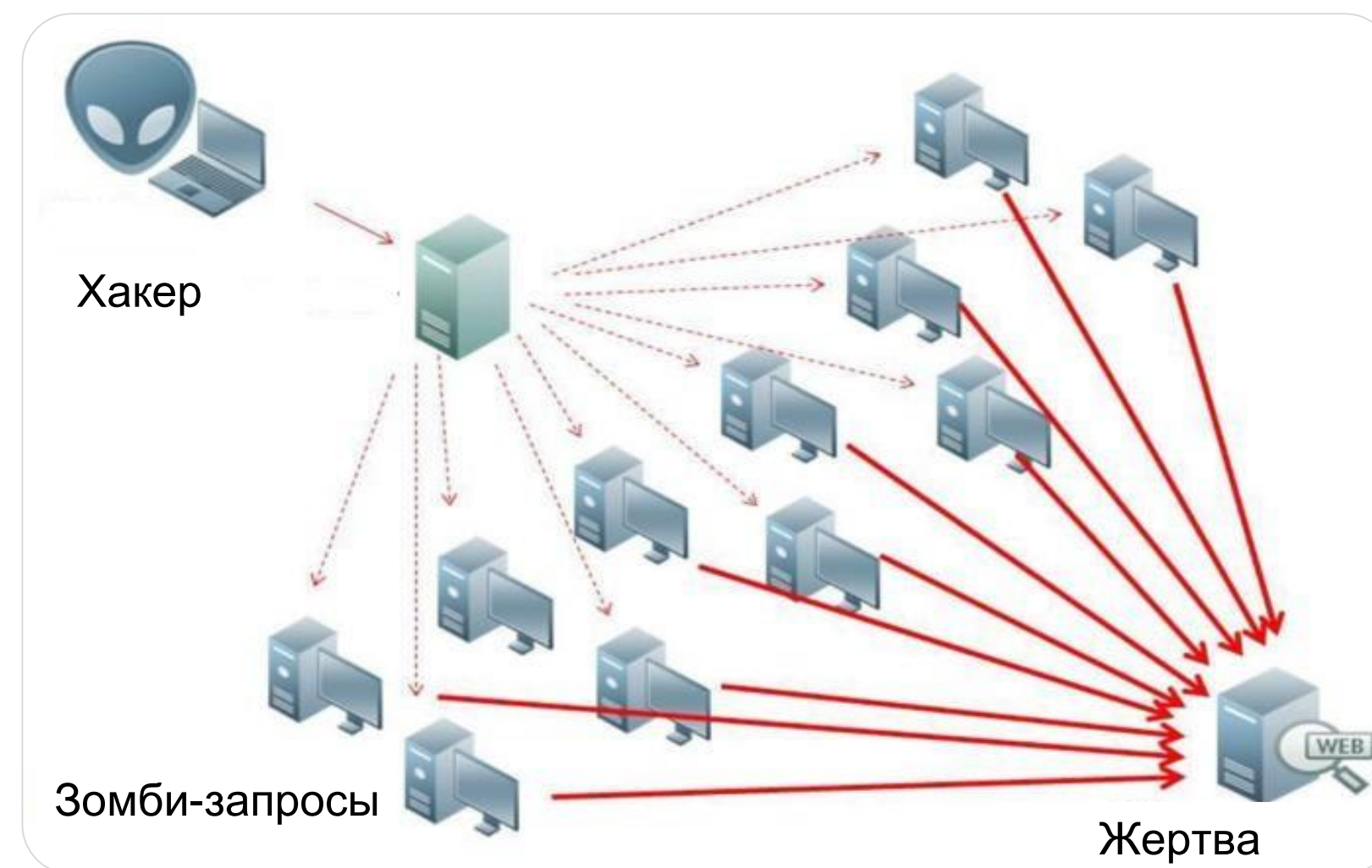


Изображение: [SYN Flood](#)

Dos/DDoS

Атака типа «отказ в обслуживании» (DoS) — это атака из одного источника, которая пытается нарушить работу служб, предоставляемых другой системой.

Распределённая атака типа «отказ в обслуживании» (DDoS) включает несколько компьютеров, атакующих одну цель. DDoS-атаки обычно включают в себя устойчивый аномально высокий сетевой трафик.



Изображение: [DDoS](#)

Атаки, направленные на ОС Linux

1. Эксплуатация уязвимостей в серверном программном обеспечении BIND
2. Уязвимости в веб-серверах на Linux/UNIX
3. Атаки на слабые пароли пользователей
4. Атаки через уязвимости в популярных системах контроля версий
5. Атаки на SNMP
6. Часто используют уязвимости в OpenSSL
7. Эксплуатация через неправильно настроенные демоны NIS и NSF
8. Эксплуатация через выставленные наружу и непропатченные базы данных
9. Уязвимости ядра
10. Атаки на выставленные наружу лишние сервисы и порты

Задача № 1 — несанкционированное получение привилегий более высокого уровня для дальнейшего продвижения и закрепления по сети.

За счёт чего можно повысить привилегии:

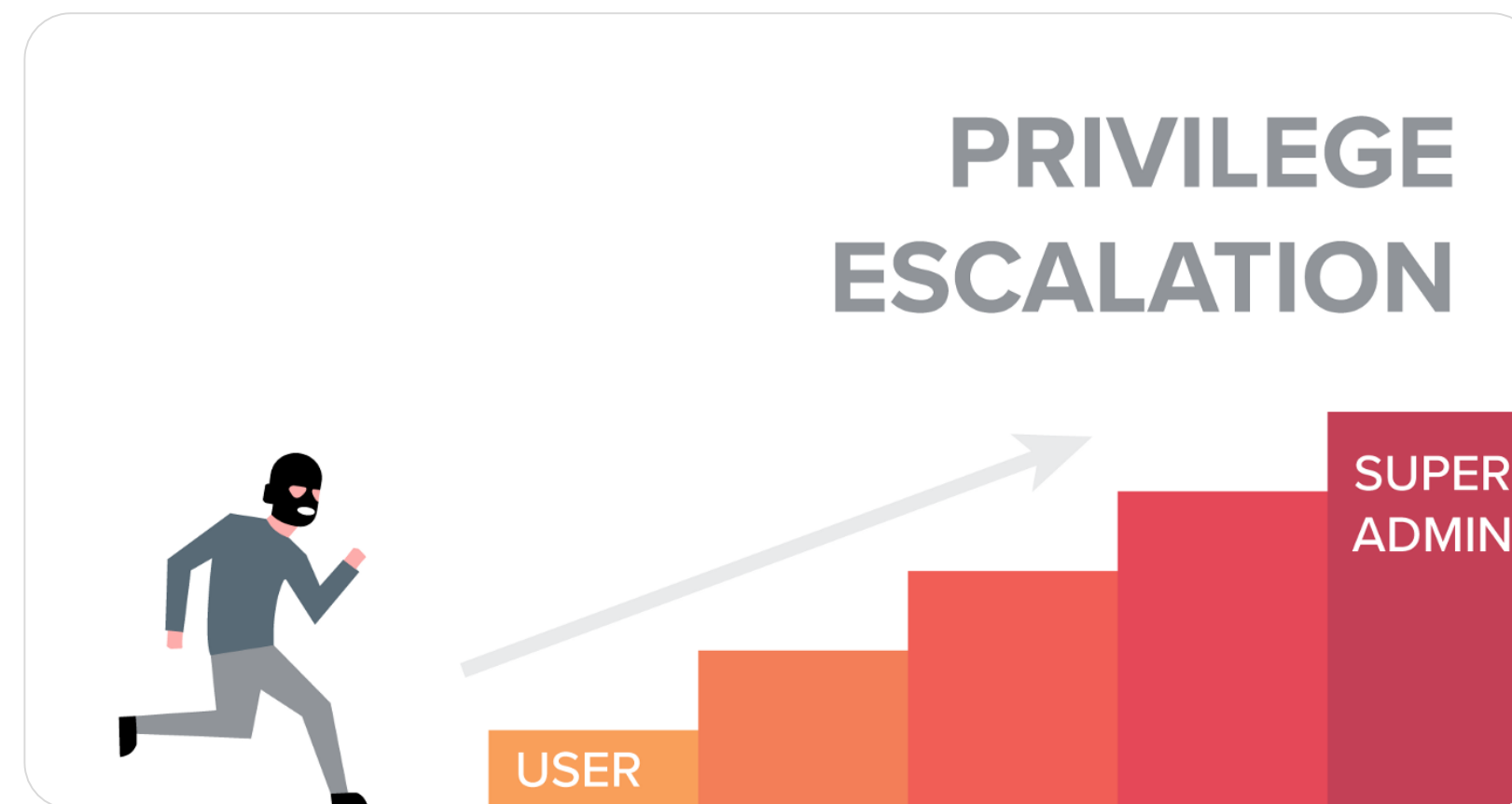
- эксплуатируя уязвимости демонов
- повышение привилегий через специального пользователя
- повышение привилегий за счёт ошибки в SUID/SGID-программах
- повышение привилегий через .rhosts и hosts.equiv

Пользователи в Linux

- Суперпользователь — неограниченные права
- Обычный пользователь — права, ограниченные ему суперпользователем
- Специальный пользователь — права, ограниченные ему суперпользователем для работы с конкретным приложением
- Псевдопользователь — нет никаких прав, он вообще не идентифицируется системой

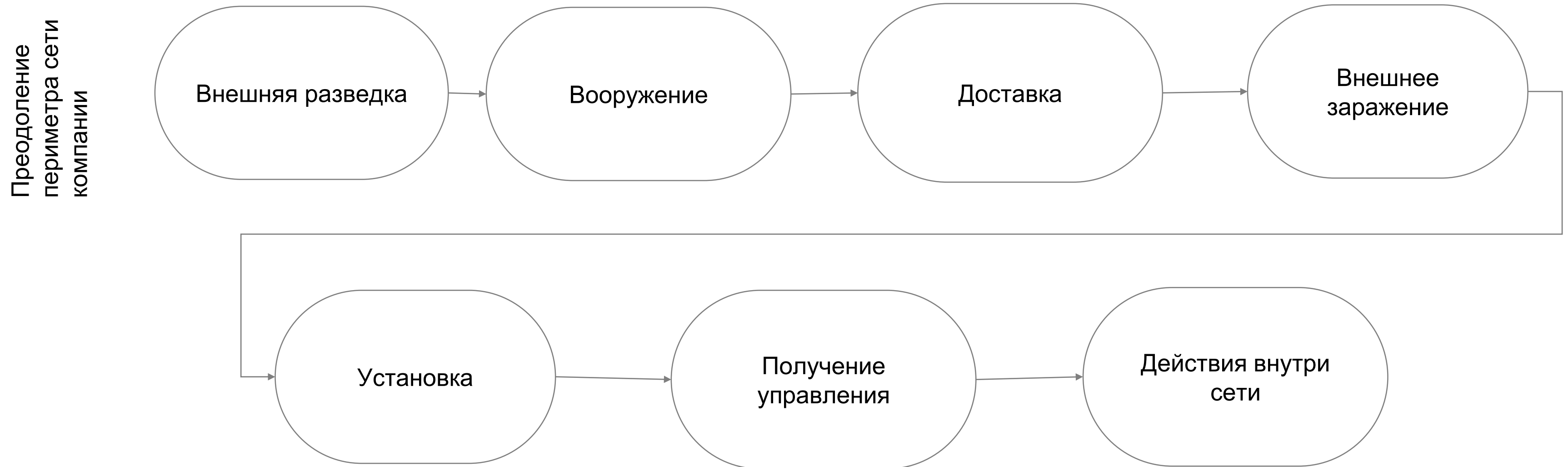
Повышение привилегий

- Эксплуатируя недостатки демонов
- Повышение привилегий из специального пользователя в обычного
- Повышение привилегий из обычного в суперпользователи
- Через системы доверия



Изображение: [Privilege Escalation](#)

Cyber-Kill Chain



Матрица ATT&CK Matrix for Enterprise

Reconnaissance 10 techniques		Resource Development 7 techniques		Initial Access 9 techniques		Execution 12 techniques		Persistence 10 techniques		Privilege Escalation 12 techniques		Defense Evasion 42 techniques		Credential Access 16 techniques		Discovery 20 techniques		Lateral Movement 9 techniques		Collection 17 techniques		Command and Control 16 techniques		Exfiltration 9 techniques		Impact 12 techniques		
Active Scanning (2)		Acquire Infrastructure (2)		Drive-by Compromise		Command and Scripting Interpreter (2)		Account Manipulation (2)		Abuse Elevation Control Mechanism (2)		Abuse Elevation Control Mechanism (2)		Adversary-in-the-Middle (2)		Account Discovery (2)		Exploitation of Remote Services		Adversary-in-the-Middle (2)		Application Layer Protocol (2)		Automated Exfiltration (1)		Account Access Removal		
Gather Victim Host Information (3)		Compromise Accounts (2)		Exploit Public-Facing Application		Container Administration Command		BITS Jobs		Access Token Manipulation (2)		Access Token Manipulation (2)		Brute Force (2)		Application Window Discovery		Internal Spearphishing		Archive Collected Data (2)		Communication Through Removable Media		Data Transfer Size Limits		Data Destruction		
Gather Victim Identity Information (2)		Compromise Infrastructure (2)		External Remote Services		Deploy Container		Boot or Logon Autostart Execution (1)(2)		Boot or Logon Autostart Execution (1)(2)		Boot or Logon Autostart Execution (1)(2)		Credentials from Password Stores (2)		Browser Bookmark Discovery		Lateral Tool Transfer		Audio Capture		Data Breeding (2)		Exfiltration Over Alternative Protocol (2)		Data Encrypted for Impact		
Gather Victim Network Information (2)		Develop Capabilities (2)		Hardware Additions		Exploitation for Client Execution		Boot or Logon Initialization Scripts (2)		Boot or Logon Initialization Scripts (2)		Boot or Logon Initialization Scripts (2)		Exploitation for Credential Access		Cloud Infrastructure Discovery		Remote Service Session Hijacking (2)		Automated Collection		Data Obfuscation (2)		Exfiltration Over OS Channel		Data Manipulation (2)		
Gather Victim Org Information (2)		Establish Accounts (2)		Phishing (2)		Inter-Process Communication (2)		Debugger Evasion		Create or Modify System Process (2)		Debugger Evasion		Forced Authentication		Cloud Service Dashboard		Remote Services (2)		Browser Session Hijacking		Dynamic Resolution (2)		Exfiltration Over Other Network Medium (1)		Defacement (2)		
Phishing for Information (2)		Obtain Capabilities (2)		Replication Through Removable Media		Native API		Compromise Client Software Binary		Create or Modify System Process (2)		Domain Policy Modification (2)		Forge Web Credentials (2)		Cloud Service Discovery		Replication Through Removable Media		Clipboard Data		Encrypted Channel (2)		Exfiltration Over Physical Medium (1)		Disk Wipe (2)		
Search Closed Sources (2)		Stage Capabilities (2)		Supply Chain Compromise (2)		Scheduled Task/Job (2)		Create Account (2)		Event Triggered Execution (1)(2)		Domain Policy Modification (2)		Host Capture (2)		Cloud Storage Object Discovery		Software Deployment Tools		Data from Cloud Storage Object		Data from Configuration Repository (2)		Exfiltration Over Web Service (2)		Endpoint Denial of Service (2)		
Search Open Technical Databases (2)				Trusted Relationship		Shared Modules		Create or Modify System Process (2)		Process Injection (1)(2)		Exploitation for Privilege Escalation		Multi-Authentication Process (2)		Container and Resource Discovery		Taint Shared Content		Data from Information Repositories (2)		Multi-Stage Channels		Scheduled Transfer		Inhibit System Recovery		
Search Open Websites/Domains (2)				Valid Accounts (2)		Software Deployment Tools		Event Triggered Execution (1)(2)		Scheduled Task/Job (2)		Hijack Execution Flow (1)(2)		Multi-Factor Authentication Interception		Debugger Evasion		Use Alternate Authentication Material (2)		Data from Local System		Non-Application Layer Protocol		Transfer Data to Cloud Account		Network Denial of Service (2)		
Search Victim-Owned Websites						System Services (2)		External Remote Services		Valid Accounts (2)		Indirect Command Execution		Multi-Factor Authentication Request Generation		Domain Trust Discovery				Data from Network Shared Drive		Protocol Tunneling				Resource Hijacking		
						User Execution (2)		Hijack Execution Flow (1)(2)				Process Injection (1)(2)		Network Sniffing		File and Directory Discovery				Data from Removable Media		Proxy (2)				Service Stop		
						Windows Management Instrumentation		Implant Internal Image				Scheduled Task/Job (2)		OS Credential Dumping (2)		Group Policy Discovery										System Shutdown/Reboot		
								Modify Authentication Process (2)				Valid Accounts (2)		Hide Artifacts (1)(2)		File and Directory Permissions Modification (2)												
								Office Application Startup (2)						Hijack Execution Flow (1)(2)		Wide Area Networks (2)												
								Pre-OS Boot (2)						Impair Defenses (2)		Wide Area Networks (2)												
								Scheduled Task/Job (2)						Indicator Removal on Host (2)		Hijack Execution Flow (1)(2)												
								Server Software Component (2)						Indirect Command Execution		Impair Defenses (2)												
								Traffic Signaling (1)						Malware (2)		Pre-OS Boot (2)												
								Valid Accounts (2)						Modify Authentication Process (2)		Pre-OS Boot (2)												
													Modify Cloud Compute Infrastructure (2)		Process Injection (1)(2)													
													Modify Registry		Reflective Code Loading													
													Modify System Image (2)		Rogue Domain Controller													
													Network Boundary Bridging (1)		Rootkit													
													Obfuscated Files or Information (2)		Subvert Trust Controls (2)													
													Plist File Modification		System Binary Proxy Execution (1)(2)													
													Pre-OS Boot (2)		System Script Proxy Execution (1)													
													Process Injection (1)(2)		Template Injection													
													Reflective Code Loading		Traffic Signaling (1)													
													Malware (2)		Trusted Developer Utilities Proxy Execution (1)													
													Unused/Unsupported Cloud Regions		Virtualization/Sandbox Evasion (2)													
													Use Alternate Authentication Material (2)		Weaken Encryption (2)													
													Valid Accounts (2)		XSL Script Processing													
													Virtualization/Sandbox Evasion (2)															
													Weaken Encryption (2)															
													XSL Script Processing															

Изображение: [данные с сайта attack.mitre.org](https://attack.mitre.org)

Выводы

В этом видео вы узнали, какие типы атак бывают. Познакомились с сетевыми атаками и популярными атаками на ОС Linux. Узнали, через какие основные недостатки злоумышленники преодолевают периметр сети компании. Познакомились с Cyber-Kill Chain и матрицей mitre ATT&CK.